RegoMender: A Multi-agent Framework for Automated Rego Policy Repair

Ruijie Zhang*
jeffy353866@gmail.com
Institute of Information Engineering, Chinese Academy of Sciences
Beijing, China
School of Cyber Security, University of Chinese Academy of Sciences
Beijing, China

Huaxiao Yin*
beautysheep4021@163.com
Institute of Information Engineering, Chinese Academy of Sciences
Beijing, China
School of Cyber Security, University of Chinese Academy of Sciences
Beijing, China

Li Hu*†
pdxbshx@mail.ustc.edu.cn
University of Science and Technology of China
Hefei, China

Fanqi Kong
17358190815@163.com
Peking University
Beijing, China

Haozhe Liang
lianghaozhe2024@163.com
University of Chinese Academy of Sciences
Beijing, China

Shaoyin Cheng‡
sycheng@ustc.edu.cn
University of Science and Technology of China
Hefei, China

Kun Zhang†
zhangkun@iie.ac.cn
Institute of Information Engineering, Chinese Academy of Sciences
Beijing, China
School of Cyber Security, University of Chinese Academy of Sciences
Beijing, China

Bibo Tu
tubibo@iie.ac.cn
Institute of Information Engineering, Chinese Academy of Sciences
Beijing, China
School of Cyber Security, University of Chinese Academy of Sciences
Beijing, China

arXiv:2610.29456v1 [cs.SE] 21 Oct 2026

Abstract

Policy-as-Code (PaC) has emerged as a foundational paradigm in cloud-native systems. However, repairing Rego policies remains challenging due to their strict syntax, declarative semantics, and specific verification requirements. Existing automated program repair (APR) methods are mainly designed for mainstream languages and struggle to accommodate the unique policy logic and repair workflows of Rego. Thus, Rego policy repair remains a manual process driven by trial and error. To address this, we introduce RegoBench, the first automated Rego policy benchmark comprising 1,159 real-world defects, and propose RegoMender, a feedback-guided multi-agent framework. Collaborating via a shared blackboard and an atomic toolkit, RegoMender dynamically executes patching, rewriting, or rolling back, to resolve complex repair scenarios. Evaluated on RegoBench, RegoMender achieves syntactic and test-based semantic success rates of 82.9% and 77.9%, respectively, outperforming the strongest baseline by 13.4%. Unlike other approaches whose performance drops in complex scenarios, RegoMender maintains effectiveness across single-step and chained repair tasks. Furthermore, it generalizes strongly across HCL and SQL and achieves an 86.4% repair rate on 132 real-world CVE vulnerabilities, proving its robustness and practical utility for security.

CCS Concepts

• **Software and its engineering** → **Constraint and logic languages**; • **Security and privacy** → **Software security engineering**; **Domain-specific security and privacy architectures**.

Keywords

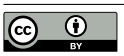
Policy-as-Code, Automated Program Repair, Rego, Multi-agent Systems, Large Language Models, Cloud Native Security

ACM Reference Format:
Ruijie Zhang, Huaxiao Yin, Li Hu, Fanqi Kong, Haozhe Liang, Shaoyin Cheng, Kun Zhang, and Bibo Tu. 2026. RegoMender: A Multi-agent Framework for Automated Rego Policy Repair. In *Proceedings of the 41st IEEE/ACM International Conference on Automated Software Engineering (ASE '26), October 12–16, 2026, Munich, Germany.* ACM, New York, NY, USA, 13 pages. https://doi.org/10.1145/3832783.3837490

1 Introduction

Policy-as-Code has become a core paradigm for enforcing security and compliance requirements in cloud-native systems. It represents policies as executable rules that are continuously evaluated against structured artifacts, such as API requests, configuration objects, and

*Ruijie Zhang, Huaxiao Yin, and Li Hu contributed equally to this research.
†Li Hu and Kun Zhang are the corresponding authors.
‡Also affiliated with Anhui Province Key Laboratory of Digital Security, Hefei, China.



This work is licensed under a Creative Commons Attribution 4.0 International License.

ASE '26, Munich, Germany

© 2026 Copyright held by the owner/author(s).

ACM ISBN 979-8-4007-2882-2/2026/10
https://doi.org/10.1145/3832783.3837490

infrastructure-as-code (IaC) plans, across both delivery and runtime environments. A widely adopted implementation of PaC is Open Policy Agent (OPA), which separates policy logic from application code and provides a unified evaluation framework across heterogeneous platforms. In practice, OPA is integrated into CI/CD pipelines for pre-deployment validation and into Kubernetes admission control to prevent non-compliant resource updates. OPA policies are written in Rego, a declarative language designed to express policy rules over inputs and produce authorization decisions [39].

However, repairing Rego policies is particularly challenging because of their declarative semantics and strict validation requirements. Unlike imperative languages, Rego follows a logic programming paradigm derived from Datalog, where unification combines pattern matching with variable binding. This context sensitivity means that even a seemingly simple modification may unintentionally alter the logic of the policy. Furthermore, policy evaluation may return `undefined` when certain data paths are missing. Rather than raising an error, this result may cause conditions to be skipped.

Meanwhile, the current APR benchmarks [26, 27, 48, 57] have been developed primarily for mainstream programming languages and rely on test suites as correctness oracles. Classic datasets such as Defects4J [27] provide standardized collections of real-world Java bugs with regression tests, while repository-level benchmarks like SWE-bench [26] evaluate issue resolution in large-scale Python repositories, collectively advancing research in APR. However, dedicated benchmarks for evaluating the automated repair of Rego policies are absent. Unlike conventional programs, policies written in Rego are validated through a tool-driven workflow that includes linting and compilation, policy-specific testing, and compliance checks derived from domain requirements.

This mismatch presents two fundamental challenges for the automated repair of Rego policies: **(i) Lack of benchmarks for Rego repair.** To date, there is no publicly available dataset specifically designed for Rego policy repair, making it difficult to systematically evaluate whether existing APR or LLM-based approaches can effectively handle Rego-specific syntax, semantics, and verification workflows. **(ii) Heavy reliance on manual or ad hoc LLM-based repair workflows.** In practice, Rego policy repair still relies heavily on manual debugging by domain experts or on ad hoc interactions with LLMs , developers must manually interpret policy failures, construct prompts, invoke `opa check` and `opa test`, assess the verification outcomes, and iteratively revise candidate patches. This human-in-the-loop repair process is time-consuming, error-prone, and difficult to scale, especially when repairs must preserve repository-specific policy intent and compliance semantics.

To address the lack of systematic data and reproducible evaluation for Rego policy repair, we mine real-world defect fixes from 2,847 GitHub repositories that actively maintain Rego policies. We then design a strict three-stage filtering pipeline to progressively refine the raw commit-level candidates, including isolated patch extraction, redundancy and noise mitigation, and deterministic verification under a standardized OPA toolchain. This process yields 1,159 high-quality buggy-fix pairs that are fully reproducible. This benchmark covers seven OPA-derived defect types, preserves the natural difficulty distribution of real-world defects and features a high proportion of complex chained repairs, directly measuring how well repair methods handle practical programming tasks.

Furthermore, we design RegoMender, a multi-agent framework for automated Rego policy repair. RegoMender establishes a closed loop between code repair and OPA verification by coordinating three specialized roles, namely the Orchestrator, Analyzer, and Repairer, through a shared Blackboard and an auditable atomic toolkit. Specifically, all repository interactions are carried out through the atomic toolkit, which provides five core operations: `Verify`, `Context Scan`, `Error Triage`, `Rewrite`, and `Patch`. This design ensures that each repair step remains precise and reproducible. Guided by real-time verifier feedback, the Orchestrator coordinates the Analyzer and Repairer, records progress on the Blackboard, and rolls back when necessary to avoid stagnation. In this way, RegoMender supports reliable multi-step repair, particularly in cases where resolving one failure exposes additional hidden defects.

To evaluate the effectiveness of RegoMender, we conduct extensive experiments on RegoBench. First, the results show that, compared to existing automated program repair methods [5, 20, 53, 58], RegoMender achieves syntactic and test-based semantic success rates of 82.9% and 77.9%, respectively. It ranks first across all seven defect types, demonstrating the effectiveness of our agent orchestration and task decision-making mechanisms. Second, we analyze the impact of different backbone models on RegoMender and the baselines. We find that RegoMender demonstrates superior robustness across different models , and DeepSeek-V3.1-Terminus [34] provides the best balance between performance and cost. Third, we conduct a comparative study on single-step and chained repair tasks. We find that RegoMender maintains stable performance in both situations. Furthermore, we conduct an ablation study on the designed atomic toolkit. The results reveal that the `Context Scan` tool has the most significant impact on the framework's performance. This indicates that the repair process for the Rego policies relies on context gathering . To evaluate its cross-language generalizability, we extend our method to two additional domain-specific languages (HCL and SQL). The results show that RegoMender continues to maintain a significant advantage over other baselines. Finally, to verify its practical utility in the real world, we evaluate our method on 132 CVE vulnerabilities. RegoMender achieves a repair rate of 86.4%, outperforming ThinkRepair and RepairAgent and demonstrating its practical potential for security-related repair.

In summary, our contributions are as follows:

- To the best of our knowledge, this is the first work to explore automated repair of Rego policies, laying the groundwork for systematic and reproducible research in this area.
- We introduce RegoBench, the first benchmark for automated Rego policy repair. To construct it, we design a three-stage filtering pipeline and apply it to 2,847 GitHub repositories that actively maintain Rego policies, curating a high-quality dataset of 1,159 real-world defects.
- We propose RegoMender, a multi-agent framework where Orchestrator, Analyzer, and Repairer agents collaborate via a Blackboard and an auditable toolkit to achieve Rego repairs with rollback-based stagnation control.
- Extensive evaluations demonstrate that RegoMender achieves state-of-the-art test-based semantic success rates of 77.9%, outperforming the strongest baseline by 13.4%. Notably, it exhibits exceptional stability in complex multi-step defects and successfully resolves 86.4% of real-world CVEs.

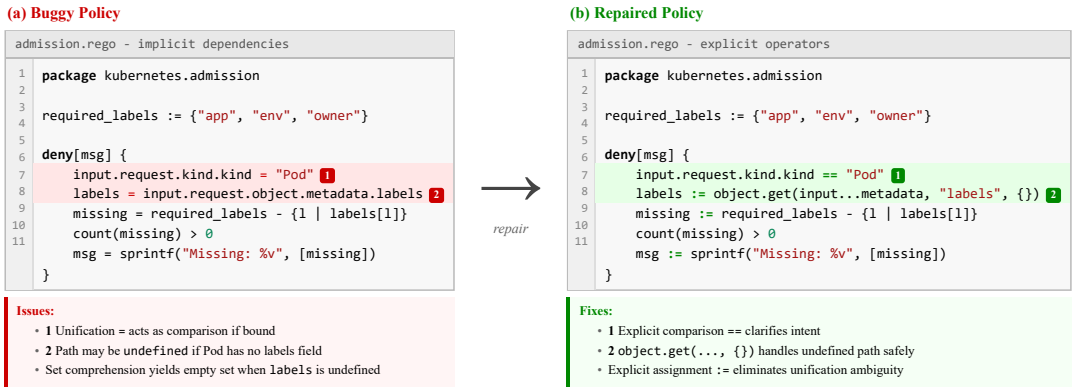


Figure 1: An Example for Rego Policy Repair.

2 Motivation

Figure 1 shows a motivating example of Rego policy repair. In Figure 1(a), the buggy rule uses unification (=) and directly reads `input.request.object.metadata.labels` after checking that the resource kind is `"Pod"`. Under Rego's undefined-value semantics, if the labels field is absent or the binding fails, the rule body may become `undefined`, so the intended deny decision is not produced. In Figure 1(b), the repair uses explicit comparison (==) for the kind check, retrieves labels with `object.get(input...metadata, "labels", )`, and uses strict assignment (`:=`) for derived values. These changes handle missing labels explicitly and restore a well-defined admission decision. This example shows why Rego repair is language-specific. The operators =, `:=`, and == represent unification, assignment, and comparison rather than simple symbol replacements, and whether an input path is defined depends on the runtime context. Therefore, Rego repairs should be validated with the standard OPA toolchain (`opa check` and `opa test`) to avoid deployment failures. Current LLMs also have limited experience with Rego repair because repair data remains scarce, making reliable decisions from prior patterns difficult.

Based on the above analysis, we construct RegoBench, a benchmark of 1,159 Rego repair instances covering a broad range of syntax and semantic errors, and propose RegoMender, a multi-agent framework for automated Rego policy repair. Recent software engineering systems use specialized agents for planning, analysis, coding, and tool use [18, 19, 45, 50]. However, such collaboration does not directly address Rego-specific needs in policy semantics, context extraction, and OPA-based verification. To address these needs, our framework coordinates three specialized agents via a shared toolkit and blackboard for automated Rego policy repair.

3 Overview

In this section, we first describe the construction of the proposed benchmark, RegoBench (§3.1), followed by a detailed presentation of our multi-agent repair framework, RegoMender (§3.2).

3.1 RegoBench Construction

We construct RegoBench, the first benchmark dedicated to real-world Rego defects, follows three main steps. First, we define each repair instance and the evaluation criteria for a successful repair. Next, we execute the data filtering process to collect high-quality instances from open-source repositories. Finally, we classify the benchmark along several characteristic dimensions to provide a comprehensive overview of the dataset.

3.1.1 ***Instance Definition.*** We define each repair instance through four core components that encapsulate all necessary context, ensuring each defect is self-contained and independently verifiable:

- **Code Pair.** We store two versions of the policy code: C_{bug} and C_{fix}. C_{bug} represents the defective policy, while C_{fix} is the corresponding manual fix. Alongside the raw code, we record metadata, such as the commit hash, repository link, and relative file paths. This information enables the precise historical code state to be retrieved and replayed deterministically.
- **Controlled Context.** This component includes dependency resolution results, the module import graph, and generated code stubs. These elements allow for isolated verification, meaning the policy can be evaluated locally without the need to download or configure the entire repository.
- **Standardized Toolchain.** We enforce a fixed OPA version (v1.10.1) and consistent command line arguments. This ensures consistent diagnostic messages and removes any variability that might arise from using different tool versions.
- **Two-Tier Oracle Records.** We organize verification into two tiers. The first ensures syntactic correctness via `opa check`, covering syntax errors, linking issues, type mismatches, and safety violations. The second ensures semantic correctness via `opa test` to prevent logical regressions. To qualify as a valid repair instance, the code must pass both tiers, guaranteeing that every sample is syntactically and behaviorally correct.

3.1.2 ***Data Filtering.*** To construct the initial corpus, we query the GitHub Search API for repositories containing `.rego` files. To ensure data quality and relevance, we apply a strict activity filter, retaining only repositories with at least 40 commits between January 1, 2020, and June 30, 2024. This yields 2,847 qualified repositories. We then analyze their commit histories to extract potential defect repairs, resulting in 54,821 raw candidates. However, extracting these defects from open source repositories introduces noise. Specifically, we observe four patterns of invalid repairs. First, superficial fixes occur when commits labeled as repairs consist only of formatting changes or code refactoring. Second, invalid repairs occur when developers simply delete code to pass checks without fixing the actual

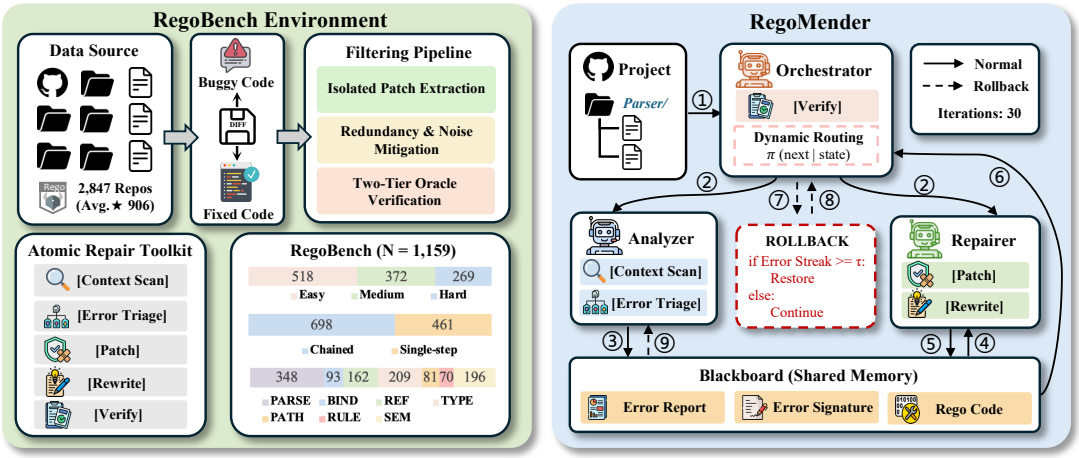


Figure 2: Overview of RegoBench Construction and RegoMender Workflow.

defect. Third, coupling across files scatters the repair logic across multiple formats, such as Rego, YAML, and Go, making it difficult to isolate the core defect. Fourth, environmental instability arises when failures depend on external variables or continuous integration contexts that are difficult to reproduce. We therefore design a three-stage filtering pipeline to obtain a high-quality dataset.

1) Isolated Patch Extraction. To resolve coupling across files, we enforce a strict single-file pairing rule. Only commits with substantive edits confined to a single `.rego` file are retained, ensuring a clear mapping between the defective and fixed states at the same file path. Nonfunctional edits are discarded to ensure each instance represents a meaningful repair. This filtering step reduces the raw corpus from 54,821 to 8,643 candidates.

2) Redundancy & Noise Mitigation. To reduce noise from repetitive patches, we implement a clear deduplication strategy. We first exclude forked and archived repositories and then use file fingerprints, defined by the repository, commit hash, and file path, to prevent redundant processing. Additionally, we apply content hashing to eliminate identical code copies caused by version control operations. Finally, we manually audit the dataset to discard samples where the link between the code change and the verification result is unclear. Through this process, we retain 3,071 candidates.

3) Two-Tier Oracle Verification. Finally, to ensure reproducibility and eliminate environmental inconsistencies, we establish a deterministic two-tier verification process using the standard OPA toolchain. Each retained instance must satisfy strict evaluation criteria. First, the defective policy must trigger a verifiable failure (via either `opa check` or `opa test`) to confirm the presence of a bug. Second, the developer fix must successfully pass both verification tiers. This process guarantees that every accepted instance is both syntactically valid and behaviorally correct.

Following this three-stage filtering pipeline, we refine the raw data into a dataset of 1,159 high-quality and reproducible instances.

3.1.3 ***Dataset Characterization.*** Following standard practices [26, 27, 31, 49] in benchmark construction, we preserve the natural distribution of the filtered dataset. To characterize this dataset, we classify the repair difficulty into three levels: easy, medium, and hard. We then engage three senior developers to manually evaluate and classify the 1,159 repair instances. To measure the consistency of their independent evaluations, we calculate the Fleiss' Kappa [12] statistic. The resulting score is 0.85, which indicates an almost perfect agreement among the three developers. For the few instances with conflicting classifications, the developers hold discussions to review the instances and reach a final consensus. The labeling results reveal that 518 instances fall into the easy category, 372 into the medium category, and 269 into the hard category. This proportion is consistent with previous empirical findings [29, 44, 60], confirming that real software defects naturally concentrate on simpler errors.

Table 1: Defect Taxonomy of RegoBench.

Defect Type	Symptom	Number
PARSE	parse error / rule-head / Rego.v1	348
BIND	binding operator / scope	93
REF	unsafe var / undefined ref / import mismatch	162
TYPE	type error / arity / built-in / helper contract	209
PATH	missing path / input shape	81
RULE	recursion / conflicting rules / defaults	70
SEM	`opa test` failure after `opa check`	196
Total	—	**1,159**

Beyond repair difficulty, we characterize the benchmark by repair dependency, categorizing instances as single-step or chained repairs. Specifically, an instance is classified as single-step if the initial error category remains unchanged until the repair successfully passes both evaluation tiers. In contrast, an instance is labeled as chained if resolving the initial error exposes at least one subsequent error category before overall success. Based on this error-driven definition, 698 instances are chained repairs and the remaining 461 are single-step repairs, as shown in Figure 2.

We further characterize each RegoBench instance by its initial defect type. Based on OPA verification feedback, we define seven categories: PARSE, BIND, REF, TYPE, PATH, RULE, and SEM. For a chained repair, the defect type is determined by the first error exposed during verification. Table 1 presents the definition, typical symptoms, and number of instances for each category.

3.2 RegoMender Framework

RegoMender is an automated multi-agent framework designed for repairing Rego policies. As shown in Figure 2, our approach centers on an Orchestrator that manages a continuous feedback loop driven by the results of `opa check` and `opa test`. The Orchestrator

coordinates two specialized agents, namely the Analyzer and the Repairer, using a shared blackboard to exchange state information. To make precise code changes and prevent the repair process from getting stuck, RegoMender includes an atomic repair toolkit, as well as a mechanism for stagnation detection and rollback. We detail these core components and the overall execution workflow below.

3.2.1 ***Components.*** Each part RegoMender takes on a distinct role to ensure a smooth repair process. We outline their specific tasks and internal logic below.

Atomic Repair Toolkit. To make the system behavior auditable and reproducible, we abstract all operations into five atomic tools. These tools serve as the sole interface for the agents:

- **Verify:** Provides the system source of truth by running syntax and semantic checks to return a formal set of errors.
- **Context Scan:** Extracts an abstract syntax tree and a dependency graph from the current policy to help agents understand the available variables and packages.
- **Error Triage:** Converts raw error information into a structured format containing the error category, line location, and the specific message associated with each line.
- **Patch:** Conducts corrections on individual code lines, such as modifying a variable name, flipping a logical operator, or refining a specific policy constraint.
- **Rewrite:** Replaces entire policy blocks or regenerates complex logic when simple edits are insufficient.

Blackboard. To reduce context loss in multi-agent collaboration, RegoMender uses a structured shared blackboard as the central repository for the system state. This component contains three fields: (i) the Code Field, which maintains a versioned history of the Rego code, allowing the system to retrieve previous code snapshots for rollback; (ii) the Report Field, which stores the sequence of structured diagnostic reports generated by the Analyzer, including the error category, line location, corresponding error message, relevant context information extracted by the `Context Scan` tool, and a priority value to guide the Repairer in fixing critical issues first; and (iii) the Error Signature Field, which maintains a tuple $\langle \textit{Error Category}, \textit{Error Count}, \textit{Error Streak} \rangle$. We define the first two elements as a state ($state = \langle \textit{Error Category}, \textit{Error Count} \rangle$), which serves as the main signal for agent routing. The *Error Streak* then records the number of consecutive occurrences of the same $state$. This allows the Orchestrator to monitor the persistence of failure patterns, enabling it to trigger rollbacks or strategy adjustments.

Orchestrator. The Orchestrator serves as the decision-maker and quality controller of RegoMender. It does not generate code directly but coordinates the workflow by dispatching tasks to the Analyzer or the Repairer. Its strategy is determined by a decision rule $\pi(next \mid state)$, where $next \in \{\textit{Analyzer}, \textit{Repairer}, \textit{Rollback}, \textit{Done}\}$ and state captures the current error category and count. In each iteration, the Orchestrator retrieves the latest code from the Blackboard and invokes the `Verify` tool. If verification fails, the Orchestrator updates the Error Signature and selects the next action based on the current repair state and explicit routing conditions defined in its prompt. Localized failures with clear line-level diagnostics are treated as simple errors and sent directly to the Repairer. Ambiguous, dependency-related, or repeatedly unresolved failures are treated as complex errors and sent to the Analyzer for additional context and dependency analysis before repair. After each repair, the Orchestrator invokes Verify again. A changed state indicates progress and resets the Error Streak, whereas an unchanged state triggers a revised diagnosis from the Analyzer. Once the predefined stagnation threshold is reached, the Orchestrator rolls back to the snapshot saved before the stalled attempts and requests a new diagnosis. The workflow concludes as *Done* only after the policy passes both syntactic and semantic validation. To prevent infinite loops, the Orchestrator monitors the repair progress and stops the process if the maximum iteration limit is reached.

Analyzer. The Analyzer acts as the diagnostic specialist, engaged by the Orchestrator when error messages are too complex or ambiguous for direct repair. Upon receiving this task, it retrieves the latest error stream and uses the `Error Triage` tool to extract a structured error description, mapping each error to its category, line location, and corresponding message. At the same time, the `Context Scan` tool extracts context and dependency information for the identified code region. The Analyzer then analyzes each error to infer its underlying cause and synthesizes these findings into a diagnostic report written to the shared blackboard.

Repairer. As the execution specialist, the Repairer modifies the Rego code based on the diagnostic report retrieved from the Blackboard. It uses `Rewrite` tool for normalization or a high volume of structural issues (i.e., more than 10 errors), and `Patch` tool for localized faults. The resulting patch list specifies the affected lines and edits, after which the repaired code is synchronized back to the Blackboard for the next verification round.

Stagnation Detection and Rollback Mechanism. To prevent infinite loops caused by complex dependency chains, the Orchestrator continuously monitors repair progress. In our framework, stagnation is defined as a state where no meaningful progress is made. Specifically, we consider the repair progress stalled if the Error Signature remains unchanged for 5 consecutive iterations ($\tau = 5$). When this happens, the Orchestrator triggers a rollback by retrieving the Rego code snapshot from the Blackboard that existed before the stagnation began. It then dispatches the Analyzer to review the historical reports stored on the Blackboard and reflect on why the previous attempts failed. Instead of a standard analysis, the Analyzer re-evaluates the persistent errors and their dependencies to issue a revised diagnostic report. This allows the Repairer to change its approach and try a different repair path to find a successful solution.

3.2.2 ***Workflow.*** The Orchestrator manages RegoMender as a feedback loop for repairing a faulty Rego repository. It extracts the initial code, stores it in the Code Field of the Blackboard, and invokes the `Verify` tool on the latest code in each iteration for syntactic and semantic testing. If all tests pass, the workflow terminates as *Done*. Otherwise, the Orchestrator updates the Error Signature Field and selects the next action based on the current $state$. For simple errors, it dispatches the Repairer to use the `Patch` or `Rewrite` tool; for complex errors, it invokes the Analyzer to synthesize raw logs and dependency context into the Report Field. To prevent infinite loops, the Orchestrator tracks the *Error Streak*. If the $state$ remains unchanged for 5 iterations, it rolls back to the snapshot saved prior to the stagnation. The Analyzer then reviews prior reports, revises the diagnostic strategy, and provides fresh guidance to the Repairer. This diagnosis, repair, and verification cycle continues until the

policy is repaired or the process reaches the maximum limit of 30 iterations. We set the iteration limit and stagnation threshold based on our practical repair experience to balance repair effectiveness with computational efficiency.

4 Experimental Setup

We design a series of experiments to evaluate the effectiveness and efficiency of RegoMender. Our study is guided by the following **Research Questions (RQs):**

- **RQ1:** How effective is RegoMender in repairing Rego policies?
- **RQ2:** How do different LLM backbones impact the performance of RegoMender?
- **RQ3:** How does RegoMender utilize collaborative tool orchestration to resolve chained repairs?
- **RQ4:** How does each atomic tool contribute to RegoMender?
- **RQ5:** To what extent does RegoMender generalize to domain-specific language similar to Rego?
- **RQ6:** Can RegoMender repair vulnerabilities in real-world deployment scenarios?

4.1 Baselines

Since automated Rego policy repair remains unexplored, we modify several existing automated repair methods [5, 19, 20, 50, 53, 58] to make them applicable to our study. We categorize them into standalone repair methods and general-purpose agent systems.

Standalone Repair Methods. This category includes state-of-the-art (SOTA) automated program repair work tailored for LLMs. Specifically, Agentless [53] is a lightweight approach that avoids complex agent loops by using a strict two-phase pipeline of fault localization and patch generation. ThinkRepair [58] enhances patch quality by prompting the model to generate a structured thought process before outputting code. APR-MCTS [20] integrates LLMs with Monte Carlo Tree Search (MCTS) [6] to explore possible patches using test feedback as reward signals, while RepairAgent [5] formulates bug fixing as an interactive task where the LLM autonomously gathers context to construct a repair.

General-Purpose Agent Systems. This category covers general-purpose agent systems designed for repository-level software engineering rather than specifically for automated program repair. It covers both multi-agent strategies and off-the-shelf coding agents. AutoDev [50] uses a conversation manager to coordinate repository-level tasks and execute commands, while MetaGPT [19] assigns specialized roles to agents to support collaboration similar to that of a software development team. Claude Code [3] and Codex [41] are off-the-shelf coding agents that can inspect repository context, modify source files, and execute development tools. We evaluate both coding agents through their official SDKs.

We evaluate all baselines in RQ1. To manage costs, RQ2–RQ6 focus on two representative baselines: ThinkRepair and RepairAgent. To mitigate LLM randomness, we repeat each experiment three times and report the average performance.

4.2 Metrics

As defined in § 3.1.1, each RegoBench instance is stored as a four-part record: a code pair $(C_{\text{bug}}, C_{\text{fix}})$, the controlled context $\mathcal{R}$, a pinned toolchain configuration $\boldsymbol{\theta}$, and the two-tier oracle protocol. For metric definitions, we only need the executable repair task induced by this record. We therefore view each instance under evaluation as $x = \big(c^{(0)}, \mathcal{R}, O_1, O_2\big)$, where $c^{(0)} = C_{\text{bug}}$, $\mathcal{R}$ is the controlled context used for verification, and O_1, O_2 are the Tier-1 and Tier-2 oracles instantiated under the toolchain $\boldsymbol{\theta}$. Given a candidate c, the oracles return verifiable outcomes and diagnostics:

$$O_1(c;\mathcal{R}) \in \{\texttt{pass}, \texttt{fail}\} \times \mathcal{D}_1,$$
$$O_2(c;\mathcal{R}) \in \{\texttt{pass}, \texttt{fail}\} \times \mathcal{D}_2,$$

where $\mathcal{D}_1$ contains `opa check` reports and $\mathcal{D}_2$ contains failing-test logs from `opa test`. Tier-2 is evaluated only after Tier-1 passes.

Although Tier-2 provides an executable evaluation of policy behavior, the available tests may not cover all intended policy semantics. To strengthen this evaluation, we adopt the LLM-as-a-Judge paradigm [14, 17, 24] and use GPT-5.4 [42] as a binary semantic judge. The judge is invoked only after a candidate passes Tier-2 and does not participate in repair generation. It classifies the repair as either `preserved` or `changed`, based on whether the repair fixes the target defect without introducing unintended changes to the policy behavior. The developer-written fix is provided only to the judge as a reference for the intended behavior.

The repair methods generate a candidate sequence $c^{(0)}, \ldots, c^{(T)}$ within T iterations. For an instance passing both Tier-1 and Tier-2, let $\widehat{c}(x)$ denote the Tier-2-passing candidate returned by the repair method. We use $\mathcal{J}^{\checkmark}(\widehat{c}(x); x, C_{\text{fix}})$ to denote that the judge classifies this candidate as preserved. Using the indicator $\mathbb{I}$, we define:

$$\text{Pass@Tier-1}(x) = \mathbb{I}\big[\exists\, t \le T : O_1^{\checkmark}(c^{(t)})\big]$$
$$\text{Pass@Tier-2}(x) = \mathbb{I}\big[\exists\, t \le T : O_1^{\checkmark}(c^{(t)}) \wedge O_2^{\checkmark}(c^{(t)})\big]$$
$$\text{JudgePass}(x) = \mathbb{I}\big[\text{Pass@Tier-2}(x) = 1 \wedge \mathcal{J}^{\checkmark}(\widehat{c}(x); x, C_{\text{fix}})\big]$$

Pass@Tier-1 measures syntax-level success, Pass@Tier-2 measures test-based semantic success, and JudgePass further requires the repaired policy to preserve the intended policy behavior. In our paper, repair success rates reported for Rego in RQ2-RQ4 and RQ6 refer to Pass@Tier-2. RQ1 additionally reports Pass@Tier-1 and JudgePass, while RQ5 uses the native oracle of each DSL.

To quantify trajectory stability, we track the number of newly introduced errors during the repair process. Let V_t denote the total violation count at step t. We measure the regression magnitude at each step as the increase in errors compared to the previous step. The overall regression score is defined as the average number of new errors introduced per round:

$$\text{Regress}(t) = max(0, V_t - V_{t-1}),$$
$$\text{Regr.\%} = \frac{1}{T}\sum_{t=1}^{T} \text{Regress}(t)$$

Under this definition, revealing a deeper-stage error after clearing an earlier blocker is treated as progress rather than regression.

5 Experimental Results

5.1 RQ1: Overall Performance

Table 2 and Figure 3 present the comparative evaluation results on RegoBench across different difficulty levels and defect types, using DeepSeek-V3.1-Terminus [34] as the backbone for all baselines.

Table 2: Performance Comparison of Repair Methods on RegoBench.

Method	Pass@Tier-1 (%)				Pass@Tier-2 (%)				JudgePass (%)				Cost / Effort			
	Easy	*Medium*	*Hard*	*Overall*	*Easy*	*Medium*	*Hard*	*Overall*	*Easy*	*Medium*	*Hard*	*Overall*	*Budget ($)*	*Time (h)*	*LLM Calls*	*Regr.%*
Standalone Methods																
Agentless [53]	66.7±1.8	60.0±1.6	46.7±1.9	59.9±1.5	61.4±1.7	54.0±1.5	41.1±1.8	54.3±1.4	58.0±1.6	50.2±1.5	37.0±1.6	50.6±1.3	4.8±0.2	2.6±0.2	2,614±74	17.5±1.6
ThinkRepair [58]	71.1±2.0	46.9±1.8	27.8±1.6	53.3±1.4	65.1±1.9	42.0±1.6	24.1±1.4	48.2±1.1	60.2±1.9	37.9±1.5	20.9±1.5	43.9±1.2	3.9±0.2	2.2±0.1	1,998±61	26.3±1.8
APR-MCTS [20]	73.3±1.9	54.5±1.7	46.7±1.8	61.1±1.5	67.4±1.8	49.1±1.6	41.1±1.7	55.4±1.7	64.0±1.7	45.9±1.5	37.0±1.7	51.9±1.6	6.2±0.3	2.7±0.2	4,995±118	15.8±1.4
RepairAgent [5]	84.6±1.6	64.2±1.4	51.5±1.5	70.4±1.3	78.5±1.5	58.4±1.3	45.8±1.4	64.5±1.2	75.9±1.4	55.4±1.5	42.4±1.4	61.5±1.3	5.2±0.2	2.9±0.2	2,664±72	14.8±1.2
General-Purpose Agent Systems																
MetaGPT [19]	72.5±2.1	54.7±1.8	41.1±1.9	59.5±1.6	66.4±1.9	49.3±1.7	36.1±1.8	53.9±1.3	62.4±1.8	45.4±1.7	31.9±1.7	49.9±1.4	9.7±0.4	5.5±0.3	5,012±121	21.5±1.9
AutoDev [50]	79.2±1.8	61.0±1.6	48.2±1.7	66.2±1.5	73.2±1.7	55.1±1.5	42.5±1.6	60.3±1.5	69.5±1.6	51.4±1.5	38.3±1.8	56.4±1.3	6.8±0.3	3.9±0.2	3,511±96	19.2±1.6
Claude Code [3]	86.0±1.4	71.0±1.4	53.0±1.7	73.5±1.3	78.0±1.5	60.0±1.2	43.0±1.6	64.1±1.4	75.4±1.5	57.3±1.4	40.3±1.3	61.4±1.1	12.4±0.4	5.8±0.3	5,210±130	13.5±1.3
Codex [41]	83.0±1.6	67.0±1.5	49.0±1.7	70.0±1.4	74.0±1.6	56.0±1.6	39.0±1.8	60.1±1.3	71.4±1.2	53.4±1.4	36.5±1.9	57.5±1.5	11.2±0.3	5.1±0.2	4,820±124	14.2±1.4
RegoMender	**97.3**±0.8	**78.5**±0.9	**61.2**±1.1	**82.9**±1.0	**94.0**±0.8	**72.3**±0.9	**54.8**±1.0	**77.9**±0.9	**92.5**±0.9	**70.3**±0.7	**52.3**±1.2	**76.0**±0.7	**8.7**±0.2	**4.9**±0.1	**4,481**±83	**7.7**±0.8

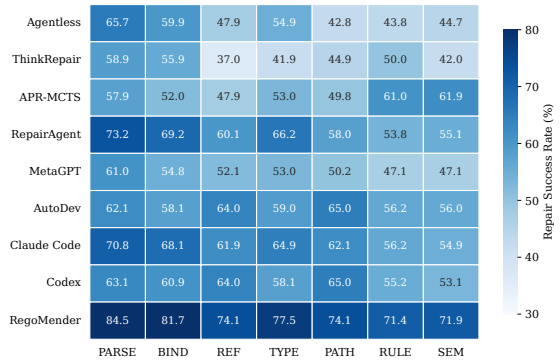


Figure 3: Repair Success Rates for Different Defect Types.

Among the standalone baselines, RepairAgent performs the best, achieving 70.4% on Pass@Tier-1 and 64.5% on Pass@Tier-2, clearly outperforming APR-MCTS, Agentless, and ThinkRepair. This suggests that structured tool use is far more effective for Rego repair than prompting or search alone. However, RegoMender surpasses RepairAgent by a substantial margin of 12.5% on Pass@Tier-1 and 13.4% on Pass@Tier-2. This gap shows that simply providing tools to a single agent is not enough; successful repair depends heavily on dynamic orchestration that can effectively coordinate context gathering, error diagnosis, and patch generation.

This reliance on proper orchestration becomes even clearer when comparing RegoMender with general-purpose agent systems. Multi-agent strategies such as AutoDev and MetaGPT achieve Pass@Tier-2 rates of 60.3% and 53.9%, respectively. The off-the-shelf coding agents perform better, with Claude Code reaching 64.1% and Codex reaching 60.1%. Nevertheless, RegoMender exceeds them by 13.8% and 17.8%, respectively. These results suggest that general-purpose systems have difficulty handling chained Rego errors without a domain-specific workflow. In contrast, RegoMender features a tailored orchestration mechanism that coordinates the Analyzer and Repairer according to repair progress, allowing the system to make suitable task decisions and resolve complex errors.

To assess the reliability of JudgePass, three senior developers independently label a stratified sample of 300 Tier-2-passing repairs. After resolving disagreements, GPT-5.4 agrees with the final expert labels on 96.7% of the sampled repairs, with a Cohen's κ [9] of 0.81. JudgePass remains close to Pass@Tier-2 across all evaluated methods, with differences ranging from 1.9% to 4.3%. For RegoMender, JudgePass reaches 76.0%, only 1.9% below its Pass@Tier-2 rate of 77.9%. This corresponds to approximately 97.6% of its Tier-2-passing repairs being judged to preserve the intended policy behavior. The strong agreement with expert labels supports the reliability of JudgePass, while the small gap between the two metrics supports the use of `opa test` as an executable proxy for Rego semantics.

Figure 3 compares the Pass@Tier-2 rates of all baselines across the seven defect types. RegoMender ranks first for every defect type, outperforming the strongest baseline for each defect type by 9.1% to 12.5%. The largest improvement occurs for BIND, where RegoMender achieves 81.7%, compared with 69.2% for RepairAgent. It also improves PARSE and TYPE by 11.3%. For REF and PATH, RegoMender reaches 74.1%, exceeding the strongest baselines by 10.1% and 9.1%, respectively. Although RULE and SEM remain the most challenging, RegoMender achieves 71.4% and 71.9%, outperforming APR-MCTS by 10.4% and 10%. These results show that the overall improvement is not limited to parsing and binding errors but extends to dependency-related, structural, and semantic defects.

In terms of stability, RegoMender achieves the lowest regression rate across all evaluated methods at just 7.7%. Claude Code has the lowest regression rate among the baselines at 13.5%, which is still 5.8% higher than RegoMender. This gap proves that our method rarely introduces more defects when modifying code. Regarding efficiency, RegoMender naturally requires more budgets ($8.7) and time (4.9h) than most baselines due to its multi-turn verification workflow. However, this added cost is a highly worthwhile trade-off. It directly translates into an absolute 13.4% improvement in overall Tier-2 success over the strongest baseline, making the moderate increase in effort entirely justified.

Answer to RQ1: RegoMender outperforms all baselines, achieving a 13.4% higher Pass@Tier-2 rate than the best baseline. Its JudgePass rate reaches 76.0%, only 1.9% below Pass@Tier-2, supporting `opa test` as a reliable proxy for semantics. RegoMender also ranks first across seven defect types and achieves the lowest regression rate of 7.7%, demonstrating broad repair effectiveness and stability across Rego defects.

5.2 RQ2: Impact of LLM Backbones

Table 3 evaluates RegoMender across ten backbone models, including six closed-source models (GPT-4.1 [40], Claude-3.5-Sonnet [1], Gemini-2.5-Flash [10], GPT-5.4 [42], Claude-4.5-Sonnet [2], Gemini-3-Flash [13]) and four open-source models (Qwen2.5-32B [46],

Table 3: Performance Comparison of Repair Methods on RegoBench across Different Backbones.

Models	Size	ThinkRepair						RepairAgent						RegoMender					
		Easy	*Medium*	*Hard*	*Overall*	*Budget*	*Time*	*Easy*	*Medium*	*Hard*	*Overall*	*Budget*	*Time*	*Easy*	*Medium*	*Hard*	*Overall*	*Budget*	*Time*
Closed-Source LLMs																			
GPT-4.1 [40]	-	72.3	47.1	28.4	54.0	21.0	3.2	58.7	40.2	32.1	46.6	26.4	4.1	89.2	72.4	58.3	76.6	47.3	7.3
Claude-3.5-Sonnet [1]	-	82.1	55.3	33.2	62.1	27.0	2.4	72.4	58.1	48.3	62.2	33.8	3.0	92.3	76.2	60.1	79.7	60.8	5.4
Gemini-2.5-Flash [10]	-	35.2	22.1	12.3	25.7	10.0	2.7	80.3	62.1	52.2	67.9	12.6	3.4	90.1	70.3	57.2	76.1	22.5	6.1
GPT-5.4 [42]	–	81.5	58.4	38.6	64.2	17.8	3.0	84.6	65.8	53.4	71.5	22.5	3.6	95.2	76.5	61.0	81.1	41.2	6.4
Claude-4.5-Sonnet [2]	–	86.6	60.7	38.4	67.1	28.1	2.5	83.6	67.1	55.7	71.8	35.1	3.1	96.8	77.8	61.2	82.4	62.4	5.6
Gemini-3-Flash [13]	–	37.0	23.5	13.5	27.2	10.9	2.9	83.5	64.6	54.3	70.6	13.6	3.6	93.3	72.2	58.5	78.4	23.1	6.2
Open-Source LLMs																			
Qwen2.5-32B-Instruct [46]	32B	21.3	14.1	7.2	15.7	2.0	1.8	38.4	18.2	14.1	26.3	2.5	2.3	84.2	64.3	50.1	69.9	4.5	4.1
Llama-3.3-70B [37]	70B	15.2	10.3	5.1	11.3	3.0	1.4	48.3	28.1	22.2	35.8	3.8	1.7	86.1	66.2	50.3	71.4	6.8	3.1
DeepSeek-V3.1-Terminus [34]	685B	65.1	42.0	24.1	48.2	3.9	2.2	78.5	58.4	45.8	64.5	5.2	2.9	94.0	72.3	54.8	77.9	8.7	4.9
DeepSeek-V4-Pro [55]	1.6T	70.4	46.5	27.5	52.5	13.6	1.9	84.6	63.3	50.0	69.7	17.4	2.4	95.3	74.0	56.0	79.5	28.2	4.1

Note: Repair success rates (Easy/Medium/Hard/Overall) are in %. Budget is in USD ($). Time is in hours (h). Underlines mark the best values within each model group.

Llama-3.3-70B [37], DeepSeek-V3.1-Terminus [34], DeepSeek-V4-Pro [55]). The results demonstrate that our framework improves repair success across model sizes and types.

Our framework significantly empowers smaller open-source models. Under the ThinkRepair baseline, smaller models struggle with complex logic. For instance, Qwen2.5-32B and Llama-3.3-70B achieve success rates of only 7.2% and 5.1% in the Hard category. This indicates that without guidance, they lack the reasoning depth for difficult semantic errors. However, when equipped with our orchestrated workflow, their performance improves dramatically. Qwen2.5-32B sees its success rate in the Hard category jump to 50.1%. This result is competitive with the much larger Gemini-2.5-Flash (57.2%) and approaches GPT-4.1 (58.3%). These results suggest that our framework helps smaller models solve difficult tasks by decomposing them into manageable steps. The benefits also extend to stronger models. Claude-4.5-Sonnet achieves an overall success rate of 82.4%, improving upon the strongest baseline result of 71.8% by 10.6 percentage points, while Gemini-3-Flash reaches 78.4%, compared with 70.6% for the strongest baseline.

In terms of cost efficiency, DeepSeek-V3.1-Terminus provides the most balanced solution. Although Claude-4.5-Sonnet achieves the highest hard-instance success rate of 61.2%, it requires a budget of $62.4. In contrast, DeepSeek-V3.1 achieves a comparable success rate of 54.8% but costs only $8.7. This represents an approximately 86% cost reduction while keeping the repair success rate close to the best result. DeepSeek-V4-Pro further improves the overall success rate to 79.5%, but its cost of $28.2 is more than three times that of DeepSeek-V3.1. These results show that RegoMender can remain effective under strict budget limits.

Answer to RQ2: RegoMender demonstrates robust generalizability across all tested models, effectively bridging the performance gap between open-source and closed-source LLMs. Claude-4.5-Sonnet achieves the highest repair success rate, while DeepSeek-V3.1-Terminus provides the best balance between repair success and cost, reaching an overall success rate of 77.9% at a cost of only $8.7.

5.3 RQ3: Efficacy of Multi-agent Orchestration

To better understand the practical challenges of Rego repair, we analyze single-step and chained repairs separately. For each category, we compare the ThinkRepair and RepairAgent baselines against RegoMender using the overall success rate.

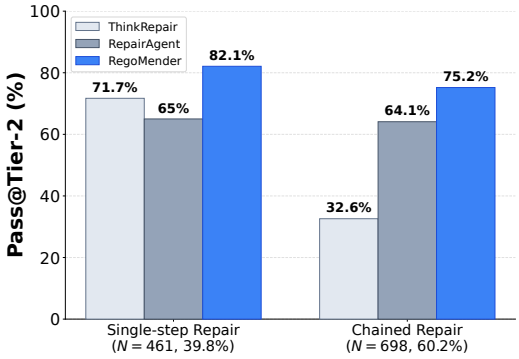


Figure 4: Repair Success: Single-step vs. Chained.

Figure 4 shows that RegoMender achieves the best performance in both categories. On single-step repairs, ThinkRepair, RepairAgent, and RegoMender achieve success rates of 71.7%, 65.0%, and 82.1%, respectively. On chained repairs, their success rates are 32.6%, 64.1%, and 75.2%. ThinkRepair shows the largest drop on chained repairs, while RepairAgent remains relatively stable. Overall, RegoMender consistently performs best in both settings, indicating stronger adaptability to single-step and chained Rego repair tasks.

Figure 5 shows a complete chained repair case where hidden failures progressively emerge as verification advances. The buggy code first fails syntax parsing due to an unsupported rule syntax (`RG-PARSE-01`), prompting an initial syntax migration to normalize the format. This migration then exposes a compilation blocker (`RG-REF-02`). The policy imports an outdated helper namespace (`data.k8s.helpers`) that has moved to `data.lib.k8s`, causing an undefined reference. After resolving the dependency by importing the correct module, the verifier reveals a type usage issue (`RG-TYPE-03`) where a boolean helper is incorrectly compared against a string literal (e.g., `== "true"`). This error requires a rewrite into a boolean predicate. The resulting code passes all syntax checks, but semantic tests still fail with a security regression (`RG-SEM-04`). Negative tests indicate the policy is missing a required non root enforcement rule, which would allow insecure pods. The repair completes only after adding the missing semantic constraint, namely a `deny` rule that enforces `not k8s.runs_as_non_root(...)`.

This scenario demonstrates why chained repair is fundamentally different from single-step editing. Early parsing and compilation failures can easily hide downstream type and security issues, and even a structurally sound policy can still fail semantic security tests. Accordingly, our framework strictly follows verification signals in

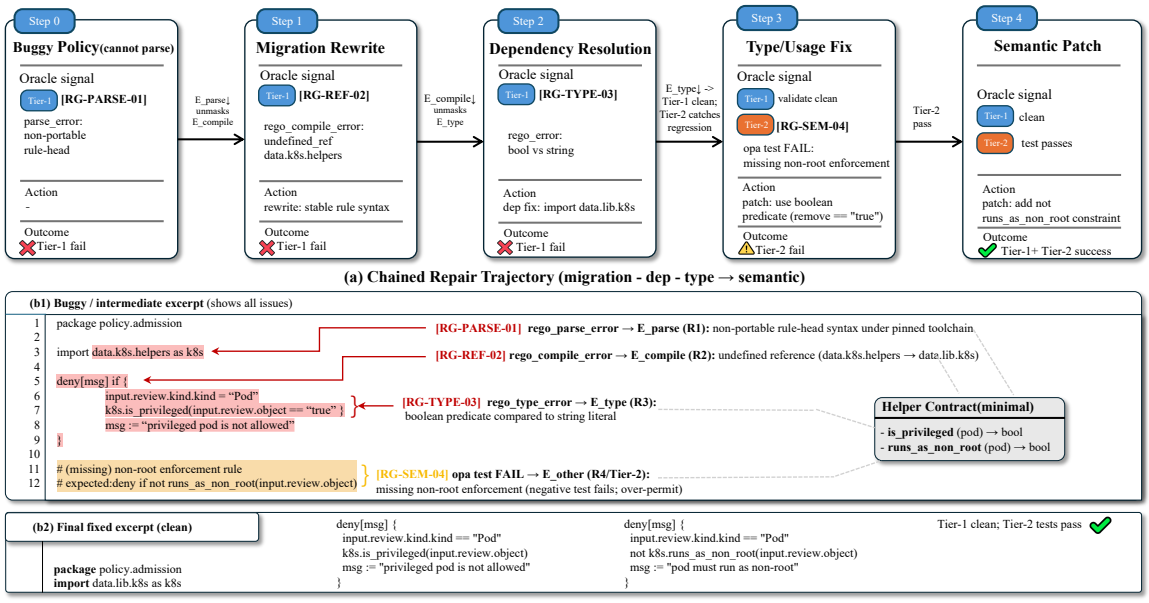


Figure 5: Chained Repair Process. RegoMender resolves syntax errors then passes semantic tests to produce a verified patch.

Table 4: Ablation Study on Tool Effectiveness.

Tool	RepairAgent (%)	RegoMender (%)
Full Toolkit	64.5	77.9
w/o *Context Scan*	49.2 (↓15.3)	61.2 (↓16.7)
w/o *Patch*	51.7 (↓12.8)	64.1 (↓13.8)
w/o *Rollback*	—	66.4 (↓11.5)
w/o *Rewrite*	56.4 (↓8.1)	68.6 (↓9.3)
w/o *Error Triage*	55.1 (↓9.4)	67.2 (↓10.7)

the correct logical sequence. It progresses from syntax migration and dependency resolution, to type correction, and finally to a semantic patch. The framework continues iterating until the policy successfully passes all verification stages.

Answer to RQ3: RegoMender achieves the highest success rate on both single-step and chained repairs. The results show that different methods vary substantially in their robustness to chained repair scenarios: ThinkRepair drops sharply on chained repairs, whereas RepairAgent remains relatively stable. In comparison, RegoMender consistently performs best in both settings, indicating stronger adaptability to single-step and chained Rego repair tasks.

5.4 RQ4: Ablation Study

Based on the ablation study in Table 4, we analyze the contribution of each tool to the overall repair success. The results identify `Context Scan` as the most critical tool. Its removal causes a severe decline in the success rate, dropping by 15.3% in the RepairAgent and 16.7% in the RegoMender. This decrease confirms that the primary challenge in Rego repair is resolving dependencies and import structures rather than merely fixing isolated syntax errors. Without scanning the broader context, the agent lacks the necessary information to understand the policy scope. Next in importance is the `Patch` tool, whose removal leads to a significant performance

Table 5: Cross-DSL Generalization Performance.

DSL	N	Avg.Errors	RepairAgent (%)	RegoMender (%)
Rego	1,159	6.2	64.5	77.9
HCL	300	4.6	78.2	82.3
SQL	100	1.0	84.0	84.0

reduction of approximately 13%. This indicates that applying precise edits is more effective than rewriting entire code blocks, which can inadvertently introduce new defects. Without Rollback, RegoMender drops from 77.9% to 66.4%, a decrease of 11.5%. This result shows that Rollback helps the framework return to an earlier stable state when a repair attempt stalls or introduces new errors, preventing unsuccessful changes from affecting later repair steps. Furthermore, the exclusion of `Error Triage` and `Rewrite` results in performance losses of around 10%. This demonstrates the necessity of filtering raw compiler messages and providing a fallback for complex logic changes. Overall, the consistent performance drops across all ablation configurations validate that every tool in our framework is essential for achieving high-performance repair.

Answer to RQ4: The ablation study demonstrates that `Context Scan` and `Patch` are the two most critical components. Removing either of these tools leads to the most significant performance drops. This finding confirms that effective Rego repair relies on resolving dependencies and making precise adjustments based on the broader scope.

5.5 RQ5: Generalizability to Other Languages

To investigate whether our framework generalizes beyond Rego, we expand our evaluation to include two other domain-specific languages, HCL and SQL, using their respective native oracles like `tf fmt` and standard SQL parsers. Applying the same filtering steps used for Rego, we collect 300 real-world HCL defects from 23 popular GitHub repositories and 100 SQL defects from 50 repositories.

Table 6: Security Policies Repair Rates by CWE Category.

CWE	Description	N	ThinkRepair	RepairAgent	RegoMender
CWE-284	Access Control	31	28.1%	71.9%	87.5%
CWE-250	Excess Privilege	28	27.6%	72.4%	89.7%
CWE-269	Privilege Mgmt	25	26.9%	69.2%	88.5%
CWE-732	Permission Assign	21	27.3%	68.2%	82.0%
CWE-863	Incorrect Authz	19	20.0%	60.0%	80.0%
Other	Mixed Types	9	30.0%	50.0%	90.0%
Total	—	**132**	**26.6%**	**67.6%**	**86.4%**

Compared to Rego, both HCL and SQL offer clearer initial error messages, but they differ greatly in repair complexity. HCL is mainly used for cloud infrastructure. While its native tools easily point out the exact line of a syntax issue, a large portion of HCL defects cannot be repaired with a single change. Because infrastructure code is highly connected, fixing one resource often exposes an error in another, requiring multi-step repairs. In contrast, SQL queries are typically self-contained. Their defects are mostly simple syntax mistakes, like a missing keyword, which usually require only one local edit without cross-file dependencies. HCL and SQL provide a perfect testbed: HCL tests multi-step repairs with clear feedback, while SQL tests simple, single-step repairs.

Table 5 indicates that the benefit of orchestration depends on the repair profile induced by the language and its oracle feedback, rather than remaining constant across DSLs. On Rego, as defects typically require repository-specific reasoning (e.g., cross-file dependencies), RegoMender improved over RepairAgent (77.9% vs. 64.5%), consistent with our main findings. On HCL, RegoMender still outperforms RepairAgent (82.3% vs. 78.2%), suggesting that orchestration remains helpful when oracle feedback is relatively precise but the repair space is still more complex than SQL. On SQL, as defects are mostly lightweight parse failures and the oracle is simpler, both methods performed identically (84.0%).

Answer to RQ5: Overall, our results suggest that generalizability depends on DSL characteristics. Orchestration methods are most effective when repair tasks rely on multi-step reasoning and feedback localization is ambiguous.

5.6 RQ6: Real-world Vulnerability Repair

To assess reliability in security critical scenarios, we evaluate the ThinkRepair, the RepairAgent, and RegoMender on 132 real-world vulnerabilities. We construct this specific subset by filtering RegoBench for instances linked to known CVE records.

Table 6 presents repair performance across different Common Weakness Enumerations (CWEs). The results highlight that direct prompting is insufficient for security patches, solving only 26.6%. However, agentic workflows significantly improve these results. Compared to the 67.6% success rate of the RepairAgent, our method reaches 86.4%, delivering a clear 18.8% overall gain. Breaking down this overall improvement by vulnerability type reveals two key trends. First, RegoMender shows consistent improvements across major categories. It outperforms the RepairAgent by 15.6% in Access Control and 19.3% in Privilege Management. This advantage expands to 20.0% for Incorrect Authorization due to complex logic. Second, our method proves robust on diverse cases. It achieves a 40.0% performance boost in the Other category. This result confirms that a multi-agent system handles diverse vulnerability types much more effectively than a single agent.

Answer to RQ6: RegoMender significantly outperforms baselines in repairing real-world vulnerabilities, achieving 86.4% success rate. More importantly, it is more reliable than RepairAgent when dealing with diverse and mixed vulnerability types.

6 Discussion

6.1 Failure Analysis

To better understand the limitations of our approach, we present a qualitative analysis of failure instances where all evaluated methods failed to produce a valid repair.

Unreachable Context. Failures often occur when project dependencies cannot be fully resolved. In complex projects, a file might rely on private modules, external code, or dynamically generated files. Since static analysis tools cannot access these missing parts, they provide an incomplete context. To fill these gaps, the model generates references or functions that look correct but are invalid. This keeps the system stuck in a loop of failed repair attempts, showing a limitation of relying solely on static analysis.

Iteration Limitation. Beyond incomplete context, strict limits on repair iterations present another major hurdle. When a task involves multiple linked errors, fixing one bug often exposes another, creating a chain of issues that requires many attempts to fully resolve. Given the need to control costs, we set a maximum iteration limit, which can cause the RegoMender repair process to end just before the code is verified. Consequently, successfully repairing deeply interconnected errors under a strict iteration budget remains a major challenge.

Semantic Ambiguity. Finally, failures can arise from coding conventions rather than simple syntax errors. A policy can be implemented in multiple valid ways, but only specific patterns align with the repository's established style, such as the choice between `deny` and `allow` layouts. Without clear examples, the model may generate a patch that is technically correct but fails strict stylistic tests or is rejected during human review.

6.2 Threats to Validity

Internal Validity. One primary threat is that a repair may satisfy `opa check` and `opa test` while failing to fully preserve the original policy intent, particularly when test coverage is incomplete and misses edge cases. Another threat involves potential noise or data contamination in mined repair data, as commit histories may include refactoring or deletions unrelated to bug fixing. We mitigate these threats in two ways. First, we construct RegoBench using a rigorous three-stage filtering pipeline and a fixed OPA toolchain to ensure each instance is reproducible and evaluated against native verification signals. Second, to strengthen semantic evaluation beyond the available tests, we combine two-tier verification and regression monitoring with JudgePass, which examines Tier-2-passing repairs for unintended changes to policy behavior. We further assess the reliability of JudgePass against expert labels on a stratified sample. The close agreement between Pass@Tier-2 and JudgePass, together with the lower regression rate of RegoMender, provides complementary evidence of semantic preservation and

repair stability. Nevertheless, incomplete tests and specifications may still leave some semantic differences undetected.

External Validity. A main external threat is that our study is centered on Rego, so the findings may not transfer equally well to other Policy-as-Code settings or to simpler DSLs with different oracle behavior. Another practical deployment threat is that real environments may involve different model choices, budget constraints, and security-sensitive scenarios. We partially address these concerns through broader evaluation. Across different LLM backbones, RegoMender consistently improves repair performance, including on smaller open-source models. Beyond Rego, the cross-DSL results on HCL and SQL suggest that the value of orchestration is not limited to one language, though the gain is larger when the repair requires multi-step reasoning. Finally, on 132 CVE-linked real-world vulnerability cases, RegoMender achieves strong results and clearly outperforms baselines. These findings support the practical relevance of our method, although further validation on more languages and production settings is still needed.

7 Related Work

7.1 Automated Program Repair

Automated program repair has emerged as a promising technique to alleviate the manual debugging burden by automatically generating patches for software defects. Traditional APR methods typically rely on test suites as specifications and can be broadly categorized into search-based and constraint-based approaches. Search-based methods, such as GenProg [32] and SimFix [25], formulate patch generation as a search problem over a syntactic mutation space. Conversely, constraint-based approaches, like SemFix [38] and Angelix [36], leverage symbolic execution to extract program semantics and synthesize patches via constraint solving. While these traditional methods have demonstrated empirical success on general-purpose programming languages like Java and C, their efficacy is often bottlenecked by the exponential search space and the scalability limitations of underlying solvers.

In recent years, the rapid advancement of deep learning has catalyzed a paradigm shift towards learning-based APR. Early data-driven approaches [8, 15, 35, 51] treated patch generation as a Neural Machine Translation (NMT) task, learning bug-fixing patterns from large-scale historical commits. More recently, large language models pre-trained on massive code corpora have exhibited remarkable capabilities in understanding code context and generating plausible patches through methods like few-shot prompting [28, 54, 58] or fine-tuning [33]. These learning-based models have significantly improved the naturalness and correctness of generated patches, pushing the boundaries of automated debugging in modern software development [11].

Despite these improvements, existing APR methods primarily focus on general-purpose languages like Java or Python, leaving a significant gap in the realm of domain-specific languages and declarative policies. Recent studies have explored related tasks in infrastructure repair and policy generation. InfraFix [48] repairs IaC scripts using verification rules designed for infrastructure configurations rather than Rego policies. ARPaCCino [47] generates Rego policies from natural-language requirements to address Terraform violations, while Prose2Policy [16] translates natural-language access-control policies into executable Rego. Overall, these systems cover IaC repair and Rego synthesis, but do not address repository-level repair of existing faulty Rego policies using the OPA toolchain. Therefore, advancing APR in this domain requires novel frameworks designed specifically to capture the underlying logic and structural constraints of declarative policies.

7.2 Multi-agent System

Multi-agent Systems (MAS) have shown strong potential in software engineering [4, 5, 21–23, 43] by decomposing complex task into collaborative workflows [18]. Existing systems generally follow two main design paradigms. The first is role-based collaboration, where agents are assigned specialized responsibilities resembling human development teams, such as planning, coding, and reviewing, as exemplified by systems like ChatDev [45] and MetaGPT [19], which aim to improve modularity and coordination in large-scale development workflows. The second paradigm focuses on tool-integrated execution, where agents operate in sandboxed environments and interact directly with external tools and verification infrastructure to support end-to-end task execution [50, 52, 56, 59].

In the context of program repair, MAS naturally enables a division of labor by separating key stages such as fault localization, patch generation, and regression testing. It is often combined with search strategies to handle noisy or ambiguous feedback. However, existing MAS-based repair approaches still face significant challenges, particularly in terms of agent coordination and integration with external verifiers [7, 30, 53]. These challenges are even more pronounced in verification-intensive domains such as Policy-as-Code. In such cases, using MAS to separate diagnosis from oracle execution proves especially beneficial, as it enables a more auditable and reproducible repair loop, while also mitigating the brittleness commonly associated with Rego policy repair [39, 47].

8 Conclusion and Future Work

In this paper, we address the challenge of applying LLM-based repair to the strict reliability requirements of cloud-native Policy-as-Code. We focus on automated Rego repair, where success requires passing a rigorous verification toolchain rather than merely generating plausible code. Our experiments show that RegoMender consistently outperforms standalone baselines and general-purpose agent systems, especially on complex, multi-step defects and security-critical issues, while reducing the risk of introducing new bugs. These results suggest that, for domain-specific language repair, system architecture can be more important than model capability alone, especially when it effectively uses repository context and verifier feedback. RegoBench and RegoMender provide a foundation for building reliable autonomous DevSecOps agents.

Building on these findings, several directions merit exploration. First, expanding RegoBench to other Policy-as-Code languages would help assess the generality of our approach. Second, because production policies often depend on external modules and dynamic cluster states, combining static analysis with sandboxed execution could capture these dependencies and improve repair accuracy. Third, syntactically valid patches may still weaken security; automated negative tests and intent-preservation checks could prevent such repairs. Finally, future work should assess the cost–benefit trade-off of multi-agent collaboration for practical deployment.

Data Availability Statement

To support reproducibility, we release a replication package containing: (i) the available portion of RegoBench, including defect instances and metadata, (ii) evaluation scripts and configuration files for reproducing the main experimental results, and (iii) sample execution traces illustrating the repair process. Artifacts are available anonymously at https://doi.org/10.5281/zenodo.19230997.

Acknowledgments

This research was partially supported by the National Cyber Security-National Science and Technology Major Project of China under Grant No. 2025ZD1500800.

References

[1] Anthropic. 2024. Introducing Claude 3.5 Sonnet. https://www.anthropic.com/news/claude-3-5-sonnet.

[2] Anthropic. 2025. Introducing Claude Sonnet 4.5. https://www.anthropic.com/news/claude-sonnet-4-5.

[3] Anthropic. 2026. Claude Code Agent SDK Overview. https://code.claude.com/docs/en/agent-sdk/overview

[4] Marco Becattini, Roberto Verdecchia, and Enrico Vicario. 2025. SALLMA: A Software Architecture for LLM-Based Multi-Agent Systems. In *2025 IEEE/ACM International Workshop New Trends in Software Architecture (SATrends)*. 5–8. doi:10.1109/SATrends66715.2025.00006

[5] Islem Bouzenia, Premkumar Devanbu, and Michael Pradel. 2025. RepairAgent: An Autonomous, LLM-Based Agent for Program Repair. In *2025 IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. 2188–2200. doi:10.1109/ICSE55347.2025.00157

[6] Cameron B. Browne, Edward Powley, Daniel Whitehouse, Simon M. Lucas, Peter I. Cowling, Philipp Rohlfshagen, Stephen Tavener, Diego Perez, Spyridon Samothrakis, and Simon Colton. 2012. A Survey of Monte Carlo Tree Search Methods. *IEEE Transactions on Computational Intelligence and AI in Games* 4, 1 (2012), 1–43. doi:10.1109/TCIAIG.2012.2186810

[7] Mert Cemri, Melissa Z. Pan, Shuyi Yang, Lakshya A. Agrawal, Bhavya Chopra, Rishabh Tiwari, Kurt Keutzer, Aditya Parameswaran, Dan Klein, Kannan Ramchandran, Matei Zaharia, Joseph E. Gonzalez, and Ion Stoica. 2025. Why Do Multi-Agent LLM Systems Fail? arXiv:2503.13657 [cs.AI] https://arxiv.org/abs/2503.13657

[8] Zimin Chen, Steve Kommrusch, Michele Tufano, Louis-Noël Pouchet, Denys Poshyvanyk, and Martin Monperrus. 2021. SequenceR: Sequence-to-Sequence Learning for End-to-End Program Repair. *IEEE Transactions on Software Engineering* 47, 9 (2021), 1943–1959. doi:10.1109/TSE.2019.2940179

[9] Jacob Cohen. 1960. A Coefficient of Agreement for Nominal Scales. *Educational and Psychological Measurement* 20, 1 (1960), 37–46. arXiv:https://doi.org/10.1177/001316446002000104 doi:10.1177/001316446002000104

[10] Gheorghe Comanici, Eric Bieber, Mike Schaekermann, Ice Pasupat, Noveen Sachdeva, Inderjit Dhillon, Marcel Blistein, Ori Ram, Dan Zhang, Evan Rosen, et al. 2025. Gemini 2.5: Pushing the frontier with advanced reasoning, multimodality, long context, and next generation agentic capabilities. *arXiv preprint arXiv:2507.06261* (2025). https://arxiv.org/abs/2507.06261

[11] Angela Fan, Beliz Gokkaya, Mark Harman, Mitya Lyubarskiy, Shubho Sengupta, Shin Yoo, and Jie M. Zhang. 2023. Large Language Models for Software Engineering: Survey and Open Problems. In *2023 IEEE/ACM International Conference on Software Engineering: Future of Software Engineering (ICSE-FoSE)*. 31–53. doi:10.1109/ICSE-FoSE59343.2023.00008

[12] Joseph Fleiss. 1971. Measuring nominal scale agreement among many raters. *Psychological Bulletin* 76 (11 1971), 378–382. doi:10.1037/h0031619

[13] Google DeepMind. 2025. Gemini 3 Flash Model Card. Technical report. https://storage.googleapis.com/deepmind-media/Model-Cards/Gemini-3-Flash-Model-Card.pdf. Accessed: 2026-07-17.

[14] Jiawei Gu, Xuhui Jiang, Zhichao Shi, Hexiang Tan, Xuehao Zhai, Chengjin Xu, Wei Li, Yinghan Shen, Shengjie Ma, Honghao Liu, Saizhuo Wang, Kun Zhang, Zhouchi Lin, Bowen Zhang, Lionel Ni, Wen Gao, Yuanzhuo Wang, and Jian Guo. 2026. A survey on LLM-as-a-judge. *The Innovation* 7, 6 (2026), 101253. doi:10.1016/j.xinn.2025.101253

[15] Rahul Gupta, Soham Pal, Aditya Kanade, and Shirish Shevade. 2017. DeepFix: fixing common C language errors by deep learning. In *Proceedings of the Thirty-First AAAI Conference on Artificial Intelligence* (San Francisco, California, USA) *(AAAI'17)*. AAAI Press, 1345–1351. https://dl.acm.org/doi/10.5555/3298239.3298436

[16] Vatsal Gupta and Darshan Sreenivasamurthy. 2026. Prose2Policy (P2P): A Practical LLM Pipeline for Translating Natural-Language Access Policies into Executable Rego. arXiv:2603.15799 [cs.AI] https://arxiv.org/abs/2603.15799

[17] Junda He, Jieke Shi, Terry Yue Zhuo, Christoph Treude, Jiamou Sun, Zhenchang Xing, Xiaoning Du, and David Lo. 2026. LLM-as-a-Judge for Software Engineering: Literature Review, Vision, and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* (Feb. 2026). doi:10.1145/3797276 Just Accepted.

[18] Junda He, Christoph Treude, and David Lo. 2025. LLM-Based Multi-Agent Systems for Software Engineering: Literature Review, Vision, and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* 34, 5, Article 124 (May 2025), 30 pages. doi:10.1145/3712003

[19] Sirui Hong, Mingchen Zhuge, Jonathan Chen, Xiawu Zheng, Yuheng Cheng, Jinlin Wang, Ceyao Zhang, Steven Yau, Zijuan Lin, Liyang Zhou, et al. 2024. MetaGPT: Meta programming for a multi-agent collaborative framework. In *International Conference on Learning Representations*, Vol. 2024. 23247–23275.

[20] Haichuan Hu, Congqing He, Hao Zhang, Xiaochen Xie, and Quanjun Zhang. 2025. APRMCTS: Improving LLM-based Automated Program Repair with Iterative Tree Search. arXiv:2507.01827 [cs.SE] https://arxiv.org/abs/2507.01827v2

[21] Li Hu, Guoqiang Chen, Xiuwei Shang, Shaoyin Cheng, Benlong Wu, Gangyang Li, Xu Zhu, Weiming Zhang, and Nenghai Yu. 2025. CompileAgent: Automated Real-World Repo-Level Compilation with Tool-Integrated LLM-based Agent System. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Wanxiang Che, Joyce Nabende, Ekaterina Shutova, and Mohammad Taher Pilehvar (Eds.). Association for Computational Linguistics, Vienna, Austria, 2078–2091. doi:10.18653/v1/2025.acl-long.103

[22] Dong Huang, Jie M. Zhang, Michael Luck, Qingwen Bu, Yuhao Qing, and Heming Cui. 2024. AgentCoder: Multi-Agent-based Code Generation with Iterative Testing and Optimisation. arXiv:2312.13010 [cs.CL] https://arxiv.org/abs/2312.13010

[23] Md. Ashraful Islam, Mohammed Eunus Ali, and Md Rizwan Parvez. 2024. MapCoder: Multi-Agent Code Generation for Competitive Problem Solving. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Lun-Wei Ku, Andre Martins, and Vivek Srikumar (Eds.). Association for Computational Linguistics, Bangkok, Thailand, 4912–4944. doi:10.18653/v1/2024.acl-long.269

[24] Hongchao Jiang, Yiming Chen, Yushi Cao, Hung-yi Lee, and Robby T. Tan. 2026. CodeJudgeBench: Benchmarking LLM-as-a-Judge for Coding Tasks. In *Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Maria Liakata, Viviane P. Moreira, Jiajun Zhang, and David Jurgens (Eds.). Association for Computational Linguistics, San Diego, California, United States, 19416–19448. doi:10.18653/v1/2026.acl-long.888

[25] Jiajun Jiang, Yingfei Xiong, Hongyu Zhang, Qing Gao, and Xiangqun Chen. 2018. Shaping program repair space with existing patches and similar code. In *Proceedings of the 27th ACM SIGSOFT International Symposium on Software Testing and Analysis* (Amsterdam, Netherlands) *(ISSTA 2018)*. Association for Computing Machinery, New York, NY, USA, 298–309. doi:10.1145/3213846.3213871

[26] Carlos E Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. 2024. Swe-bench: Can language models resolve real-world github issues?. In *International Conference on Learning Representations*, Vol. 2024. 54107–54157.

[27] René Just, Darioush Jalali, and Michael D. Ernst. 2014. Defects4J: a database of existing faults to enable controlled testing studies for Java programs. In *Proceedings of the 2014 International Symposium on Software Testing and Analysis* (San Jose, CA, USA) *(ISSTA 2014)*. Association for Computing Machinery, New York, NY, USA, 437–440. doi:10.1145/2610384.2628055

[28] Sungmin Kang, Bei Chen, Shin Yoo, and Jian-Guang Lou. 2024. Explainable automated debugging via large language model-driven scientific debugging. *Empirical Softw. Engg.* 30, 2 (Dec. 2024), 28 pages. doi:10.1007/s10664-024-10594-x

[29] Rafael-Michael Karampatsis and Charles Sutton. 2020. How Often Do Single-Statement Bugs Occur? The ManySStuBs4J Dataset. In *Proceedings of the 17th International Conference on Mining Software Repositories* (Seoul, Republic of Korea) *(MSR '20)*. Association for Computing Machinery, New York, NY, USA, 573–577. doi:10.1145/3379597.3387491

[30] Fanqi Kong, Ruijie Zhang, Huaxiao Yin, Guibin Zhang, Xiaofei Zhang, Ziang Chen, Zhaowei Zhang, Xiaoyuan Zhang, Song-Chun Zhu, and Xue Feng. 2026. Aegis: Automated error generation and attribution for multi-agent systems. In *International Conference on Learning Representations*, Vol. 2026. 52994–53028.

[31] Claire Le Goues, Neal Holtschulte, Edward K. Smith, Yuriy Brun, Premkumar Devanbu, Stephanie Forrest, and Westley Weimer. 2015. The ManyBugs and IntroClass Benchmarks for Automated Repair of C Programs. *IEEE Transactions on Software Engineering* 41, 12 (2015), 1236–1256. doi:10.1109/TSE.2015.2454513

[32] Claire Le Goues, ThanhVu Nguyen, Stephanie Forrest, and Westley Weimer. 2012. GenProg: A Generic Method for Automatic Software Repair. *IEEE Transactions on Software Engineering* 38, 1 (2012), 54–72. doi:10.1109/TSE.2011.104

[33] Guochang Li, Chen Zhi, Jialiang Chen, Junxiao Han, and Shuiguang Deng. 2024. Exploring Parameter-Efficient Fine-Tuning of Large Language Model on Automated Program Repair. In *Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering* (Sacramento, CA, USA) *(ASE '24)*. Association for Computing Machinery, New York, NY, USA, 719–731.

doi:10.1145/3691620.3695066
[34] Aixin Liu, Bei Feng, Bing Xue, Bingxuan Wang, Bochao Wu, Chengda Lu, Chenggang Zhao, Chengqi Deng, Chenyu Zhang, Chong Ruan, et al. 2024. Deepseek-v3 technical report. *arXiv preprint arXiv:2412.19437* (2024).
[35] Thibaud Lutellier, Hung Viet Pham, Lawrence Pang, Yitong Li, Moshi Wei, and Lin Tan. 2020. CoCoNuT: combining context-aware neural translation models using ensemble for program repair. In *Proceedings of the 29th ACM SIGSOFT International Symposium on Software Testing and Analysis* (Virtual Event, USA) *(ISSTA 2020)*. Association for Computing Machinery, New York, NY, USA, 101–114. doi:10.1145/3395363.3397369
[36] Sergey Mechtaev, Jooyong Yi, and Abhik Roychoudhury. 2016. Angelix: scalable multiline program patch synthesis via symbolic analysis. In *Proceedings of the 38th International Conference on Software Engineering* (Austin, Texas) *(ICSE '16)*. Association for Computing Machinery, New York, NY, USA, 691–701. doi:10.1145/2884781.2884807
[37] Meta. 2024. Llama 3.3: Model Cards and Prompt Formats. https://www.llama.com/docs/model-cards-and-prompt-formats/llama3_3/.
[38] Hoang Duong Thien Nguyen, Dawei Qi, Abhik Roychoudhury, and Satish Chandra. 2013. SemFix: Program repair via semantic analysis. In *2013 35th International Conference on Software Engineering (ICSE)*. 772–781. doi:10.1109/ICSE.2013.6606623
[39] Open Policy Agent (OPA). [n. d.]. Policy Language. https://www.openpolicyagent.org/docs/policy-language. Accessed: 2026-01-18.
[40] OpenAI. 2025. Introducing GPT-4.1 in the API. https://openai.com/index/gpt-4-1/.
[41] OpenAI. 2026. Codex SDK. https://developers.openai.com/codex/sdk
[42] OpenAI. 2026. Introducing GPT-5.4. https://openai.com/index/introducing-gpt-5-4/.
[43] Wanzong Peng, Lin Ye, Xuetao Du, Hongli Zhang, Dongyang Zhan, Yunting Zhang, Yicheng Guo, and Chen Zhang. 2025. PwnGPT: Automatic Exploit Generation Based on Large Language Models. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Wanxiang Che, Joyce Nabende, Ekaterina Shutova, and Mohammad Taher Pilehvar (Eds.). Association for Computational Linguistics, Vienna, Austria, 11481–11494. doi:10.18653/v1/2025.acl-long.562
[44] R. Purushothaman and D.E. Perry. 2005. Toward understanding the rhetoric of small source code changes. *IEEE Transactions on Software Engineering* 31, 6 (2005), 511–526. doi:10.1109/TSE.2005.74
[45] Chen Qian, Wei Liu, Hongzhang Liu, Nuo Chen, Yufan Dang, Jiahao Li, Cheng Yang, Weize Chen, Yusheng Su, Xin Cong, Juyuan Xu, Dahai Li, Zhiyuan Liu, and Maosong Sun. 2024. ChatDev: Communicative Agents for Software Development. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Lun-Wei Ku, Andre Martins, and Vivek Srikumar (Eds.). Association for Computational Linguistics, Bangkok, Thailand, 15174–15186. doi:10.18653/v1/2024.acl-long.810
[46] Qwen, :, An Yang, Baosong Yang, Beichen Zhang, Binyuan Hui, Bo Zheng, Bowen Yu, Chengyuan Li, Dayiheng Liu, Fei Huang, Haoran Wei, Huan Lin, Jian Yang, Jianhong Tu, Jianwei Zhang, Jianxin Yang, Jiaxi Yang, Jingren Zhou, Junyang Lin, Kai Dang, Keming Lu, Keqin Bao, Kexin Yang, Le Yu, Mei Li, Mingfeng Xue, Pei Zhang, Qin Zhu, Rui Men, Runji Lin, Tianhao Li, Tianyi Tang, Tingyu Xia, Xingzhang Ren, Xuancheng Ren, Yang Fan, Yang Su, Yichang Zhang, Yu Wan, Yuqiong Liu, Zeyu Cui, Zhenru Zhang, and Zihan Qiu. 2025. Qwen2.5 Technical Report. arXiv:2412.15115 [cs.CL] https://arxiv.org/abs/2412.15115
[47] Francesco Romeo, Luigi Arena, Francesco Blefari, Francesco Aurelio Pironti, Matteo Lupinacci, and Angelo Furfaro. 2026. ARPaCCino: An Agentic-RAG for Policy as Code Compliance. In *New Trends in Database and Information Systems*, Panos K. Chrysanthis, Kjetil Nørvåg, Kostas Stefanidis, Zheying Zhang, Elisa Quintarelli, and Ester Zumpano (Eds.). Springer Nature Switzerland, Cham, 467–481. doi:10.1007/978-3-032-05727-3_39
[48] Nuno Saavedra, João F. Ferreira, and Alexandra Mendes. 2025. InfraFix: Technology-Agnostic Repair of Infrastructure as Code. In *Proceedings of the 34th ACM SIGSOFT International Symposium on Software Testing and Analysis* (Clarion Hotel Trondheim, Trondheim, Norway) *(ISSTA Companion '25)*. Association for Computing Machinery, New York, NY, USA, 41–45. doi:10.1145/3713081.3731735
[49] Ripon K. Saha, Yingjun Lyu, Wing Lam, Hiroaki Yoshida, and Mukul R. Prasad. 2018. Bugs.jar: a large-scale, diverse dataset of real-world Java bugs. In *Proceedings of the 15th International Conference on Mining Software Repositories* (Gothenburg, Sweden) *(MSR '18)*. Association for Computing Machinery, New York, NY, USA, 10–13. doi:10.1145/3196398.3196473
[50] Michele Tufano, Anisha Agarwal, Jinu Jang, Roshanak Zilouchian Moghaddam, and Neel Sundaresan. 2024. AutoDev: Automated AI-Driven Development. arXiv:2403.08299 [cs.SE] https://arxiv.org/abs/2403.08299
[51] Michele Tufano, Jevgenija Pantiuchina, Cody Watson, Gabriele Bavota, and Denys Poshyvanyk. 2019. On Learning Meaningful Code Changes Via Neural Machine Translation. In *2019 IEEE/ACM 41st International Conference on Software Engineering (ICSE)*. 25–36. doi:10.1109/ICSE.2019.00021
[52] Xingyao Wang, Boxuan Li, Yufan Song, Frank F Xu, Xiangru Tang, Mingchen Zhuge, Jiayi Pan, Yueqi Song, Bowen Li, Jaskirat Singh, et al. 2025. Openhands: An open platform for ai software developers as generalist agents. In *International Conference on Learning Representations*, Vol. 2025. 65882–65919.
[53] Chunqiu Steven Xia, Yinlin Deng, Soren Dunn, and Lingming Zhang. 2024. Agentless: Demystifying LLM-based Software Engineering Agents. arXiv:2407.01489 [cs.SE] https://arxiv.org/abs/2407.01489
[54] Chunqiu Steven Xia and Lingming Zhang. 2024. Automated Program Repair via Conversation: Fixing 162 out of 337 Bugs for $0.42 Each using ChatGPT. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis* (Vienna, Austria) *(ISSTA 2024)*. Association for Computing Machinery, New York, NY, USA, 819–831. doi:10.1145/3650212.3680323
[55] Anyi Xu, Bangcai Lin, Bing Xue, Bingxuan Wang, Bingzheng Xu, Bochao Wu, Bowei Zhang, Chaofan Lin, Chen Dong, Chenchen Ling, et al. 2026. Deepseek-v4: Towards highly efficient million-token context intelligence. *arXiv preprint arXiv:2606.19348* (2026). https://arxiv.org/abs/2606.19348
[56] John Yang, Carlos Jimenez, Alexander Wettig, Kilian Lieret, Shunyu Yao, Karthik Narasimhan, and Ofir Press. 2024. SWE-agent: Agent-Computer Interfaces Enable Automated Software Engineering. In *Advances in Neural Information Processing Systems*, A. Globerson, L. Mackey, D. Belgrave, A. Fan, U. Paquet, J. Tomczak, and C. Zhang (Eds.), Vol. 37. Curran Associates, Inc., 50528–50652. doi:10.52202/079017-1601
[57] Ziyang Ye, Triet Huynh Minh Le, and M. Ali Babar. 2025. LLMSecConfig: An LLM-Based Approach for Fixing Software Container Misconfigurations. In *2025 IEEE/ACM 22nd International Conference on Mining Software Repositories (MSR)*. 629–641. doi:10.1109/MSR66628.2025.00099
[58] Xin Yin, Chao Ni, Shaohua Wang, Zhenhao Li, Limin Zeng, and Xiaohu Yang. 2024. ThinkRepair: Self-Directed Automated Program Repair. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis* (Vienna, Austria) *(ISSTA 2024)*. Association for Computing Machinery, New York, NY, USA, 1274–1286. doi:10.1145/3650212.3680359
[59] Yuntong Zhang, Haifeng Ruan, Zhiyu Fan, and Abhik Roychoudhury. 2024. AutoCodeRover: Autonomous Program Improvement. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis* (Vienna, Austria) *(ISSTA 2024)*. Association for Computing Machinery, New York, NY, USA, 1592–1604. doi:10.1145/3650212.3680384
[60] Hao Zhong and Zhendong Su. 2015. An Empirical Study on Real Bug Fixes. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, Vol. 1. 913–923. doi:10.1109/ICSE.2015.101

Received 2026-03-26; accepted 2026-06-18